

Information Disclosure - Suspicious Comments (634)

Assessment Identifier: **WS-DYN-10** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: INFORMATIONAL	CVSS: 0.0	CWE: CWE-615
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 13	Confidence: Medium
Target / Component: Client HTML Bundle Comments	Affected URL: https://www.worldmonitor.app/dashboard	Parameter: Pattern: \bFROM\b in HTML comment

1. Description

The response appears to contain suspicious comments which may help an attacker. Developers frequently leave inline code comments during testing or staging that reveal technical implementation details, internal routes, or third-party service logic.

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/dashboard.
2. Inspect the returned HTML response body.
3. Search for HTML comment blocks (`<!-- ... -->`).
4. Locate the comment describing script loading behavior: `<!-- Umami Analytics loads from the SPA after first paint/idle... -->`.

3. Controlled Proof of Concept

HTML Comment Evidence in Dashboard source:

```

<!-- Umami Analytics loads from the SPA after first paint/idle (not the document head) so a slowdown abacus origin -->

```

4. Business & Security Impact

While this specific comment is informational, leaving comments in production code leaks insight into frontend architecture, script initialization routines, and external dependencies. Attackers utilize leftover comments during reconnaissance to map out internal components or locate sensitive TODOs, API keys, or backend endpoint references.

5. Remediation Recommendations

- Primary Fix:** Implement automated comment stripping in the production CI/CD minification pipeline.
1. Implement automated build scripts or minifiers (e.g., Terser, HTMLMinifier) during CI/CD to strip all HTML, CSS, and JavaScript comments prior to production deployment.
 2. Review remaining source files to ensure no sensitive notes, credentials, or internal URLs are exposed in raw client-side code.

6. Evidence & Validation

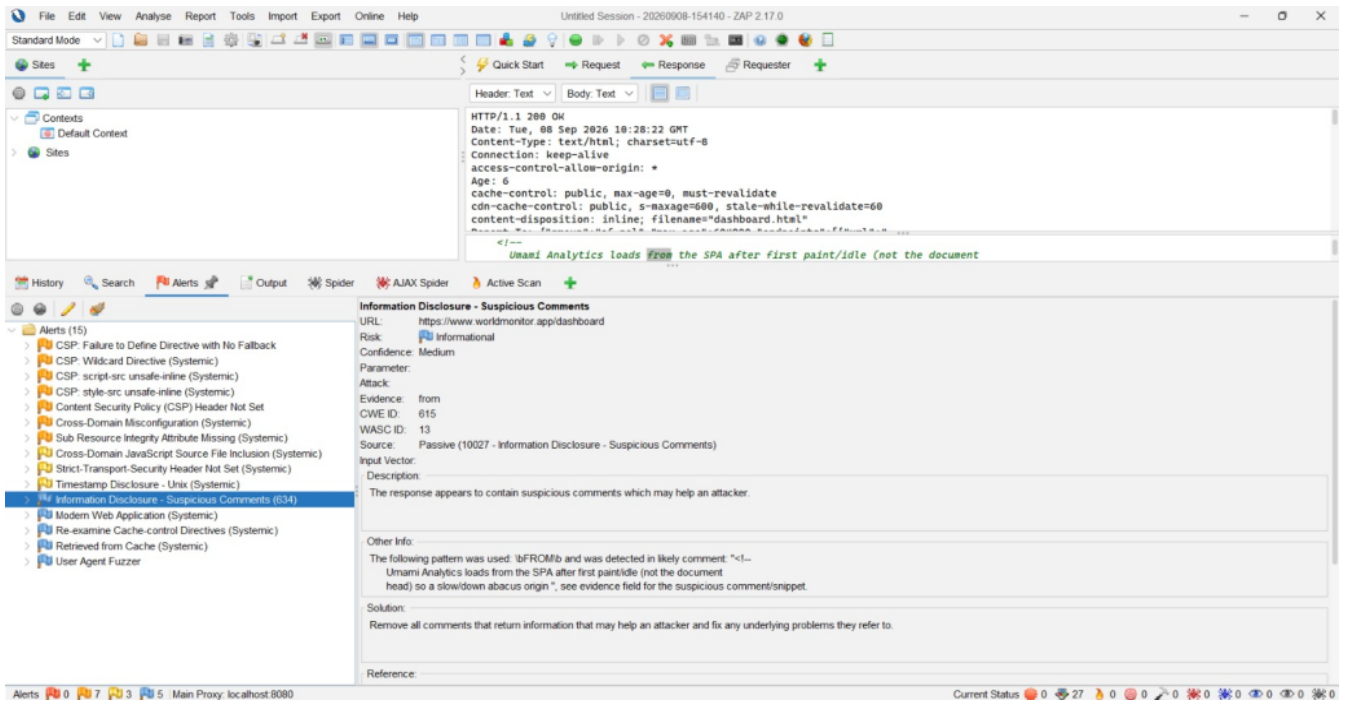


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #10 (10/poc-1.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.